Team 2: säkerhetsrapport för Blue Team

Kurs: ITSX25 kurs 6, Avancerad IT-säkerhet **Datum:** 2026-10-26 **Status:** Underlag för teamets granskning, med miljöns slutläge den 26 oktober 2026.

Sammanfattning

Team 2 har byggt och försvarat en molnbaserad miljö och en Flask-applikation. Arbetet omfattar nätverk och identitet, Terraform och CI/CD, härdning av applikationen samt kontroller för container-images och leveranskedjan. Flera brister i tidigare kod och konfiguration har åtgärdats. Det finns fortfarande risker kring behörigheter, återställbarhet, övervakning och verifiering i den nya driftsmiljön.

Den viktigaste säkerhetsprincipen är att flera kontroller samverkar: begränsad nätåtkomst och OS Login skyddar vägen in; WIF begränsar behovet av statiska molnnycklar; granskade pipelines bygger och signerar images; och Kubernetes kontrollerar vilka images som får användas. Applikationsskydd kompletterar infrastrukturens skydd. Inga enskilda kontroller garanterar säkerhet.

Rapporten skiljer mellan bekräftade historiska fynd, åtgärder i kod och driftkontroller. ATT&CK-mappning beskriver möjliga angriparbeteenden, inte bevis för ett intrång. Labbfynd från separata kursmiljöer är lärdomar och presenteras inte som incidenter i teamets egen miljö.

Omfattning och metod

Underlaget omfattar arbetet under vecka 4–7 i infra-repot och applikationsrepot, inklusive den senare migrationen till `itsx25-comerit` som Blue Team-fasens slutläge den 26 oktober 2026. Teamet avslutar fasen utifrån detta läge och planerar inga ytterligare åtgärder som del av denna examination. Bedömningen bygger på versionshanterad konfiguration, säkerhetsrapporter, pull requests, testresultat och dokumenterade kontroller. Driftbevis från den tidigare miljön är inte automatiskt giltiga för den nya. Bedömningarna nedan är preliminära och inte en oberoende revision eller ett fullständigt penetrationstest.

Allvarlighetsgrad är teamets preliminära kvalitativa bedömning, inte ett beräknat CVSS-värde. Den förutsätter att den historiska bristen är åtkomlig i ett relevant scenario. Faktisk exponering och konsekvens är inte fastställda för alla fynd.

Arkitektur och avvägningar

Område	Samlad säkerhetsbedömning
Infrastruktur och nät	**Lösning:** Terraform och GCP-brandväggar styr resurser och anslutningsvägar. I den nya miljön används IAP och OS Login för personåtkomst. **Kvarstående risk:** Behörigheter och brandväggsregler måste granskas när miljön ändras. Comerit förvaltar delar av grundmiljön.
Identitet och CI	**Lösning:** GitHub Actions använder WIF i stället för en statisk GCP service-account-nyckel. Appens deploy använder ett separat begränsat IAP-konto och Kubernetes-identity. **Kvarstående risk:** WIF eliminerar inte risken för missbruk av tokens eller överbehörighet. Kubernetes-deploytoken behöver säker lagring, rotation och återkallning.
DevSecOps	**Lösning:** PR-granskning, tester, container-build, SBOM och image-signering ger spårbarhet från kod till image. **Kvarstående risk:** Godkänd pipeline är inte ett bevis för att all kod är säker. Privilegierade ändringar och leverantörsberoenden måste granskas.
Körmiljö	**Lösning:** K3s kör appen; kontroller för signerade images har införts. Appen kör som icke-root med begränsat filsystem enligt dokumenterad hardening. **Kvarstående risk:** Flera plattformskontroller sattes upp manuellt i den nya miljön och behöver kunna återskapas. Full deploy efter att enforcement aktiverats återstår.

Område	Samlad säkerhetsbedömning
Övervakning och respons	**Lösning:** Tidigare miljö hade dokumenterad Trivy/Discord-testning; GCP-loggar och uppföljning av avvikande aktiviteter är relevanta underlag. **Kvarstående risk:** Aktuell täckning och larmkedja i Comerit är inte fullt verifierade. Incidentansvar, larmvägar och övade rutiner behöver sammanställas.
Data och tillgänglighet	**Lösning:** Appens SQLite-data använder persistent volym; `Recreate` minskar volymkonflikter vid rollout. **Kvarstående risk:** En replika och `Recreate` kan ge kort avbrott. Backup, återställning och åtkomst till data behöver verifieras separat.

Fynd, åtgärder och risker

Rader med en konkret, verifierad angreppsväg är mappade mot MITRE ATT&CK. Rader som uttryckligen anges som kontrollbrist, dokumentationslucka eller ej verifierad attackväg är kvarstående risker och inte påståenden om en observerad ATT&CK-teknik. De hålls separata för att undvika att en teknikkod presenteras utan tillräckligt stöd.

Fynd och preliminär allvarlighet	Samlad bedömning
Statisk CI-nyckel, hög vid exponering	**Åtgärd och evidens:** WIF infördes; användarhanterade nycklar togs bort enligt PB-03 och verifiering; deploy efter borttagning. **ATT&CK:** T1078.004 Cloud Accounts: missbruk av giltig molnidentitet. **Kvarstående risk:** WIF-villkor, identiteter och loggar innebär en kvarstående förvaltningsrisk.
För bred CI-behörighet, hög vid kontokompromettering	**Åtgärd och evidens:** Tidigare `roles/editor` togs bort; PR #75 separerade privilegierad IAM från normal deploy. **ATT&CK:** T1078.004 är en möjlig attackväg; överbehörighet förstärker påverkan. **Kvarstående risk:** Äldre rollavvägningar ska inte förväxlas med Comerits aktuella IAM. Minsta nödvändiga rättigheter i den nya miljön är inte fullständigt verifierade.
Bred nåtåtkomst, medel till hög beroende på tjänst	**Åtgärd och evidens:** Brandväggsregler begränsades enligt PB-05. Nya miljön använder IAP och OS Login för administrativ åtkomst. **ATT&CK:** T1021.004 SSH: möjlig fjärråtkomst om en identitet missbrukas. **Kvarstående risk:** Användare och rollnivåer innebär en kvarstående behörighetsrisk. Att en port är begränsad skyddar inte mot missbruk av godkänd identitet.
Känslig Terraform state och för bred bucketåtkomst, hög vid exponering	**Åtgärd och evidens:** Bred bindning togs bort enligt PB-02; remote state och begränsad åtkomst är dokumenterade i backloggen. **ATT&CK:** T1530 Data from Cloud Storage: möjlig insamling från molnlagring. **Kvarstående risk:** PB-02 anger fortsatt granskning. Nuvarande bucket-IAM och publikt skydd är inte fullständigt verifierade i rapportunderlaget.
SQL injection och osäkert lösenordsflöde i äldre login, hög	**Åtgärd och evidens:** Historiskt fynd i säkerhetsrapporten. Nuvarande auth.py använder parametriserad fråga och hashverifiering. **ATT&CK:** T1190 Exploit Public-Facing Application är relevant om appen exponeras för angriparen; sådan exponering förutsätts inte generellt. **Kvarstående risk:** Regressionstester och exponering i aktuell miljö är inte fullständigt verifierade i rapportunderlaget. Kodåtgärd bevisar inte att alla vägar är testade.
Otillräcklig ägarkontroll vid profiländring, hög	**Åtgärd och evidens:** Historiskt fynd; nuvarande routes.py kontrollerar användaridentitet vid profiländring och förhandsvisning. **ATT&CK:** Ingen entydig teknik kan fastställas utan en konkret attackväg. Detta är en auktorisationsbrist, inte i sig en ATT&CK-teknik. **Kvarstående risk:** Behåll negativa tester. Beslut om synlighet för egna `internal_notes` och bredare åtkomstgranskning återstår.

Fynd och preliminär allvarlighet	Samlad bedömning
Hårdkodad hemlighet och känslig seed-data, hög om verklig hemlighet exponeras	**Åtgärd och evidens:** Historiskt fynd; nuvarande config.py tar nyckel från miljön. Migreringar och historik behöver granskas separat. **ATT&CK:** T1552.001 Credentials In Files gäller möjlig insamling av faktiska uppgifter ur filer. En placeholder är inte automatiskt en aktiv credential. **Kvarstående risk:** Rotera eller återkalla faktiska exponerade hemligheter. Att ta bort ett värde i senaste kod tar inte automatiskt bort äldre kopior.
CSRF och sessionsinställningar, medel till hög beroende på exponering	**Åtgärd och evidens:** app.py använder CSRF-skydd; testsviten innehåller en negativ kontroll. **ATT&CK:** Ingen entydig ATT&CK-teknik fastställd. Mappa inte en skyddskontroll till en teknik utan en konkret angreppskedja. **Kvarstående risk:** Alla tillståndsändrande vägar och cookiekonfigurationen är inte fullständigt verifierade. Webbåtkomst via lokal HTTP-tunnel är inte generell HTTPS-verifiering.
Template-injektion i äldre signaturförhandsvisning, hög om exploaterbar	**Åtgärd och evidens:** Rapporttillägg och analys beskriver ersättning av dynamisk rendering med begränsade platshållare. **ATT&CK:** T1059.004 Unix Shell är endast en hypotetisk följd om kommandokörning kan visas; det är inte bevisat här. **Kvarstående risk:** Underlaget fastställer inte fullständig verifiering mot det ursprungliga fyndet.
Osäker leveranskedja, hög vid manipulerad image	**Åtgärd och evidens:** Pipeline genererar SBOM och signerar images. Sigstore-policy infördes; i nya miljön godkändes appens image i dry-run och en image utan matchande policy nekades. **ATT&CK:** T1195.002 Compromise Software Supply Chain är ett hot som dessa kontroller motverkar, inte ett observerat intrång. **Kvarstående risk:** Grön deploy gjordes före enforcement. En full deploy och rollback med enforcement återstår; nekad omatchad image är inte bevis för alla signeringsfall.
Skanner och larm är inte fullt reproducerbara, medel	**Åtgärd och evidens:** Trivy/Discord testades i tidigare miljö enligt skannerdokumentationen. **ATT&CK:** Ingen direkt mappning för dokumentationsluckan; T1195.002 är ett möjligt hot skanning kan bidra till att upptäcka. **Kvarstående risk:** Installation, schemaläggning och larm i Comerit är inte verifierade. Dokumentera återställning utan att publicera webhook eller secrets.

Kvarstående risker vid avslut

Följande är dokumenterade begränsningar och rekommendationer, inte en plan för ytterligare genomförande inom Blue Team-fasen:

1. Full deploy under aktiverad image-policy är inte verifierad. Manuell installation av policy-controller och RBAC innebär en återställbarhetsrisk.
2. Aktuell state-bucket och OS Login-behörigheter behöver fortlöpande förvaltning enligt ansvarsfördelningen med Comerit; alla rättigheter är inte verifierade i detta underlag.
3. Övervakning, larmmottagare och incidentrutin är inte fullt verifierade i den nya miljön. Tidigare driftbevis visar inte automatiskt aktuell täckning.
4. Appens inloggning är inte verifierad i den nya miljön. En frisk `/healthz` visar inte att alla användarflöden fungerar.
5. De äldre säkerhetsrapporterna beskriver historiska fynd och kan inte ensamma användas som aktuell statusbedömning.

Agilt arbetssätt och kvalitet

Teamet har använt issues, backlog, egna brancher, PR-granskning och CI för att prioritera och följa ändringar. Infra-backloggen och app-backloggen visar exempel på status och riskprioritering. Sammanfattningar dokumenterar uppföljning och hinder. Backlogfilerna är inte automatiskt identiska med GitHub Issues. En formell retrospektiv kan inte bekräftas enbart genom detta underlag.

Källor och granskning

- Infra: MITRE, Threat Intelligence och TLP: historiska infrastrukturbedömningar.
- App: MITRE, Threat Intelligence och TLP: appfynd, kontrollstatus och osäkerheter.
- Appens migrationsstatus: ny miljö och återstående kontroller.
- MITRE ATT&CK: referens för angriparbeteenden och teknikernas begränsningar.